

06_Cybersecurity_and_Information_Security

ALDRIDGE HARBOR PORT AUTHORITY

KESSLER POINT MARINE TERMINAL — PERIMETER SECURITY, ACCESS CONTROL AND SURVEILLANCE SYSTEMS

DOCUMENT 6 OF 13 — CYBERSECURITY AND INFORMATION SECURITY REQUIREMENTS

Solicitation Number	AHPA-2026-IFB-0417
Document Revision	Rev 0
Date	14 September 2026

SENSITIVE SECURITY INFORMATION — 49 CFR PART 1520

ABBREVIATIONS AND ACRONYMS

Term	Meaning
CISA	Cybersecurity and Infrastructure Security Agency
CSF	Cybersecurity Framework
CVE	Common Vulnerabilities and Exposures
CVSS	Common Vulnerability Scoring System
CycloneDX	An SBOM format maintained by OWASP
CySO	Cybersecurity Officer
FIPS	Federal Information Processing Standard
IEC	International Electrotechnical Commission
IT	Information Technology
MFA	Multi-Factor Authentication
NIST	National Institute of Standards and Technology
OT	Operational Technology
SBOM	Software Bill of Materials
SIEM	Security Information and Event Management
SP	Special Publication
SPDX	Software Package Data Exchange
SSI	Sensitive Security Information
USCG	United States Coast Guard
VLAN	Virtual Local Area Network

1. REGULATORY BASIS

CS-1.1 The Site is a facility required to maintain a security plan under 33 CFR Part 105 and is accordingly subject to **33 CFR Part 101 Subpart F, Cybersecurity**, published 17 January 2025 and effective 16 July 2025.

CS-1.2 The Contractor shall ensure that the systems supplied under this Contract are capable of supporting the Authority’s compliance with 33 CFR 101.650.

CS-1.3 The Contractor shall prepare the Cybersecurity Plan required by 33 CFR 101.630 in respect of the Works, and shall submit it to the United States

Coast Guard for approval prior to Final Acceptance.

CS-1.4 The Contractor shall designate a Cybersecurity Officer for the Works and shall notify the Authority of that designation in writing.

CS-1.5 The Contractor shall report any reportable cyber incident affecting the Works in accordance with 33 CFR 101.645, and shall notify the Authority immediately upon becoming aware of such an incident.

CS-1.6 Requirements of the Cybersecurity Maturity Model Certification programme do not apply to this Contract.

2. ARCHITECTURE AND SEGMENTATION

CS-2.1 The security network shall be physically separate from the terminal operational technology network and from the Authority's business information technology network.

CS-2.2 Where a connection between the security network and any other network is required for an interface described in Document 5, it shall be made through a firewall configured to permit only the specific flows required.

CS-2.3 Each subsystem shall be placed in its own VLAN. Inter-VLAN traffic shall be permitted only where required and shall be documented in the Interface Control Documents.

CS-2.4 Field devices shall not be able to initiate connections to the head end other than those required for their function.

CS-2.5 Remote access for maintenance shall be by a jump host with multi-factor authentication, session recording, and the Authority's prior approval for each session.

CS-2.6 No system shall be connected to the public internet.

CS-2.7 The architecture shall follow the guidance of **NIST SP 800-82** for operational technology security and shall be described with reference to **NIST Cybersecurity Framework 2.0**.

CS-2.8 The Contractor may have regard to **IEC 62443-3-3** in establishing system security levels. Certification to IEC 62443 is not required.

3. DEVICE AND ACCOUNT SECURITY

CS-3.1 No device shall be placed into service with a default or manufacturer-set credential.

CS-3.2 All field-connected devices shall authenticate to the network using IEEE 802.1X with certificate-based authentication.

CS-3.3 The Contractor shall supply and commission a certificate management capability for the issue, renewal and revocation of device certificates.

CS-3.4 All administrative access shall require multi-factor authentication.

CS-3.5 Accounts shall be individually attributable. Shared accounts shall not be used.

CS-3.6 Role-based access control shall be implemented, with the minimum privilege necessary for each role.

CS-3.7 All devices shall accept only firmware that is cryptographically signed by the manufacturer.

CS-3.8 Cryptographic modules protecting credential data and video shall be **FIPS 140-3 validated**.

CS-3.9 Unused physical ports and services shall be disabled.

4. SOFTWARE SUPPLY CHAIN

CS-4.1 The Contractor shall deliver a **Software Bill of Materials** for every software component supplied, in **CycloneDX or SPDX** format, at Final Acceptance and on each subsequent software change.

CS-4.2 The Software Bill of Materials shall enumerate all direct and transitive dependencies, with version identifiers.

CS-4.3 The Contractor shall confirm that no component originates from an entity named at ITB-12.2.

CS-4.4 The Contractor shall notify the Authority of any component that reaches end of support during the warranty period.

5. VULNERABILITY MANAGEMENT AND PATCHING

CS-5.1 The Contractor shall monitor manufacturer and CISA advisories for vulnerabilities affecting any supplied component.

CS-5.2 The Contractor shall apply security patches to all supplied software and firmware throughout the warranty period.

CS-5.3 The Contractor shall maintain all supplied software at a currently supported release.

CS-5.4 Patches shall be applied in accordance with industry best practice.

CS-5.5 The Contractor shall submit a quarterly vulnerability report listing all CVEs affecting supplied components, their CVSS scores, and the remediation status of each.

CS-5.6 Patching shall not be performed without the Authority's prior approval of a change request and shall be performed within an agreed maintenance window.

6. TESTING

CS-6.1 The Contractor shall arrange, at its own cost, an independent penetration test of the delivered systems prior to Final Acceptance.

CS-6.2 The penetration test shall be performed by a firm not connected with the Contractor, approved by the Authority.

CS-6.3 The scope shall include the security network, the video management system, the access control system, the pre-gate systems and all interfaces described in Document 5.

CS-6.4 All findings rated High or Critical shall be remediated and retested before Final Acceptance.

CS-6.5 The penetration test report is Sensitive Security Information and shall be handled in accordance with Annex C.

7. LOGGING AND MONITORING

CS-7.1 All systems shall generate logs of authentication events, configuration changes, administrative actions and security-relevant system events.

CS-7.2 Logs shall be forwarded to the Authority's Security Information and Event Management platform in accordance with IF-7.

CS-7.3 Logs shall be retained locally for not less than ninety (90) days.

CS-7.4 Time on all systems shall be synchronised to a common authenticated time source.

8. SENSITIVE SECURITY INFORMATION

CS-8.1 The Contractor and each of its personnel and subcontractors is a covered person within the meaning of **49 CFR 1520.7**.

CS-8.2 The Contractor shall handle all Sensitive Security Information in accordance with 49 CFR Part 1520 and Annex C.

CS-8.3 All records containing Sensitive Security Information shall be marked with the protective marking and distribution limitation statement required by 49 CFR 1520.13.

CS-8.4 Sensitive Security Information shall be transmitted only by means approved by the Authority. Personal electronic mail accounts, consumer file-sharing services and unencrypted portable media shall not be used.

CS-8.5 Sensitive Security Information shall be stored on systems under the Contractor's control, located within the United States.

CS-8.6 The Contractor shall maintain a register of every person to whom Sensitive Security Information has been disclosed.

CS-8.7 The Contractor shall notify the Authority within twenty-four (24) hours of any actual or suspected unauthorised disclosure.

CS-8.8 On completion of the Contract, the Contractor shall return or destroy all Sensitive Security Information and shall certify the same.

9. PERSONNEL

CS-9.1 Every member of the Contractor's personnel with access to Sensitive Security Information shall have a demonstrable need to know.

CS-9.2 The Contractor shall satisfy itself as to the suitability of each such person.

CS-9.3 The Contractor shall notify the Authority when any person with access to Sensitive Security Information leaves the project or the Contractor's employment.

CS-9.4 The Cybersecurity Lead identified at SOW-3.1 shall hold a current CISSP, GICSP or equivalent certification.

10. TRAINING

CS-10.1 The Contractor shall deliver cybersecurity training to the Authority's information technology personnel and to the Authority's Cybersecurity Officer, as scheduled at SOW-10.1.

CS-10.2 Training shall cover the architecture, the security controls implemented, the incident response procedure, the patching regime and the log sources.

CS-10.3 The Contractor shall provide the Authority with the material necessary to satisfy the training obligation at 33 CFR 101.650(d)(4) in respect of the supplied systems.

END OF DOCUMENT 6